IAM Authentication Methods — End-to-End Integration Document

Document type: Consumer API reference

Scope: All authentication-related APIs registered in IAM

Base URL: `{IAM_BASE_URL}` (provided per environment)

API categories (mapped to code)

Every endpoint below is tagged with a **category** that matches where it is implemented and registered in the codebase.

Category	Code package	OpenAPI spec	Route registration	What it covers
CAT-A	`internal/authentication`	`authentication.yml`	`authentication.HandlerFromMux` in `cmd/api/main.go`	Mobile OTP, MPIN, session, mobile user admin
CAT-B	`internal/authentication` (Google OIDC)	`authentication.yml`	`google_oidc_handlers.go` via same mux	Google Sign-In / OIDC
CAT-C	`internal/auth_email`	`auth_email.yaml`	`auth_email.HandlerFromMux` in `cmd/api/main.go`	Email/password register, login, profile
CAT-D	`internal/auth_email` (`invites.go`)	`auth_email.yaml`	Same `auth_email` mux	Organisation invite lifecycle
CAT-E	`internal/rbac`	`rbac.yml`	`rbac.HandlerFromMux` in `cmd/api/main.go`	Organisation create / assign (auth paths)

Handler entry points:

- `internal/authentication/orchestrator.go` — CAT-A mobile flows
- `internal/authentication/google_oidc_handlers.go` — CAT-B
- `internal/auth_email/orchestrator.go` — CAT-C
- `internal/auth_email/invites.go` — CAT-D
- `internal/rbac/orchestrator.go` — CAT-E (`MTCreateOrganization`, `MTAssignOrganizationToUser`)

Document conventions

Symbol	Meaning
■	Step completed — next step allowed
■	Step skipped or failed — flow blocked
■	JWT tokens issued
—	Not provided at this step

Required header on every call:

```
Application-Name: <YourRegisteredAppName>
```

Optional headers (when applicable):

Header	Used for
`X-Tenant-ID`	Tenant/org-scoped registration and login

Header	Used for
`org_id`	Email register (alias for org scope)
`X-Platform: Mobile`	Enforces `deviceId` on OTP / MPIN / login
`X-Platform: Web`	Device binding optional
`Authorization: Bearer <token>`	Logout, refresh (when required)

Method 1 — Mobile OTP + MPIN

Category: CAT-A (`internal/authentication` / `authentication.yml`)

Flow overview

Mandatory order: `generate-otp` → `verify-otp` → `set-mpin` → `login-mpin`

Tokens are issued **only** at step 4 (`login-mpin`).

```
App  →  1. POST /api/auth/generate-otp     →  userID, expiresIn (no tokens)
App  →  2. POST /api/auth/verify-otp       →  verified=true (no tokens)
App  →  3. POST /api/auth/set-mpin         →  userID (no tokens)
App  →  4. POST /api/auth/login-mpin       →  accessToken + refreshToken ■
```

Step 1 — Generate OTP

Category: CAT-A · Handler: `GenerateOtp` · `internal/authentication/orchestrator.go`

Endpoint

```
POST /api/auth/generate-otp
```

Request

```
POST /api/auth/generate-otp
Application-Name: MyApp
X-Tenant-ID: ORG_abc123          (optional; required for tenant-linked apps)
X-Platform: Mobile                (optional: Web | Mobile)
Content-Type: application/json


{
  "mobileNumber": "9876543210",
  "userName": "Jane Doe",
  "businessName": "Acme Corp",
  "email": "jane@example.com",
  "sms": true,
  "whatsapp": false,
  "deviceId": "device-uuid-123",
  "deviceModel": "Pixel 8",
  "osVersion": "14",
  "appVersion": "1.0.0"
}
```

Field	Required	Notes
`mobileNumber`	Yes	Valid mobile number
`userName`	No	Display name
`sms` / `whatsapp`	No	OTP delivery channel

Field	Required	Notes
`deviceId`	Yes if `X-Platform: Mobile`	Device fingerprint
Other device fields	No	Used for device binding

Success response — 200 OK

```
{
  "code": "OTP_SENT",
  "message": "OTP sent successfully",
  "userID": "USR12345",
  "expiresIn": 120,
  "referalCode": "REF001",
  "otp": "482910"
}
```

Field	Provided	Notes
`userID`	■	IAM user identifier — store for later steps
`expiresIn`	■	OTP validity in seconds (default **120**)
`referalCode`	■	When applicable
`otp`	Dev only	Present only in non-production when enabled
`accessToken`	—	**Not issued**
`refreshToken`	—	**Not issued**

Error responses

HTTP	When
400	Invalid mobile, unknown app, invalid tenant, temple not approved
409	User already registered (duplicate registration blocked)
429	Rate limit / account locked / OTP resend blocked
503	OTP service unavailable (e.g. Redis not configured)

What this step establishes

Delivered to client	Purpose
`userID`	Track user through registration
OTP on phone/email channel	User enters OTP in step 2
`expiresIn`	Show countdown; OTP invalid after expiry

If this step is removed / skipped

Next step	Result
`verify-otp`	■ 400 — user not found or no active OTP
`set-mpin`	■ 400 — user not found
`login-mpin`	■ 401 — user not registered / MPIN not set

Step 2 — Verify OTP

Category: CAT-A · Handler: `VerifyOtp` · `internal/authentication/orchestrator.go`

Endpoint

```
POST /api/auth/verify-otp
```

Request

```
POST /api/auth/verify-otp
Application-Name: MyApp
X-Tenant-ID: ORG_abc123          (must match step 1 if used)
X-Platform: Mobile
Content-Type: application/json


{
  "mobileNumber": "9876543210",
  "otp": "482910",
  "deviceId": "device-uuid-123",
  "deviceModel": "Pixel 8",
  "osVersion": "14",
  "appVersion": "1.0.0",
  "pushToken": "expo-push-token",
  "platform": "android"
}
```

Success response — 200 OK

```
{
  "code": "OTP_VERIFIED",
  "message": "OTP verified successfully",
  "mobileNumber": "9876543210",
  "verified": true,
  "timestamp": "2026-06-24T10:02:00Z"
}
```

Field	Provided	Notes
`verified`	■	`true` — account marked verified server-side
`timestamp`	■	Verification time
`accessToken`	—	**Not issued**
`refreshToken`	—	**Not issued**

Error responses

HTTP	When
400	User not found, wrong/expired OTP, invalid app/tenant, account locked
After 5 failed attempts	Account locked for **5 minutes**

What this step establishes

Delivered to client	Server-side effect (outcome for client)
`verified: true`	User may proceed to set MPIN

Delivered to client	Server-side effect (outcome for client)
MPIN setup window	**30 minutes** to call `set-mpin` (after this, window expires)
Org link	If `X-Tenant-ID` sent, user linked to organisation

If this step is removed / skipped

Next step	Result
`set-mpin`	■ 400 — "account status is not verified or active"
`login-mpin`	■ 401 — MPIN not set (`MPIN_NOT_SET`)

If generate-otp was skipped

■ 400 — "user not found" or "OTP expired"

Step 3 — Set MPIN

Category: CAT-A · Handler: `SetMpin` · `internal/authentication/orchestrator.go`

Endpoint

```
POST /api/auth/set-mpin
```

Request

```
POST /api/auth/set-mpin
Application-Name: MyApp
X-Tenant-ID: ORG_abc123
X-Platform: Mobile
Content-Type: application/json

{
  "mobileNumber": "9876543210",
  "mpin": "1234",
  "userName": "Jane Doe",
  "deviceId": "device-uuid-123",
  "deviceModel": "Pixel 8",
  "osVersion": "14",
  "appVersion": "1.0.0",
  "pushToken": "expo-push-token",
  "platform": "android",
  "roleIds": ["role_object_id"]
}
```

Field	Required	Notes
`mobileNumber`	Yes	Same as step 1
`mpin`	Yes	User's MPIN
`userName`	Yes	Display name stored at registration
`deviceId`	Yes if `X-Platform: Mobile`	
`roleIds`	No	Freelancer onboarding only

Success response — 200 OK

```
{
  "code": "MPIN_SET",
```

```
  "message": "MPIN set successfully",
  "mobileNumber": "9876543210",
  "userID": "USR12345"
}
```

Field	Provided	Notes
`userID`	■	Confirms registered user
`accessToken`	—	**Not issued**
`refreshToken`	—	**Not issued**

Error responses

HTTP	When
400	User not found, account not verified, **MPIN setup window expired** (>30 min after verify-otp), `deviceId` missing on mobile, deleted account

What this step establishes

Delivered to client	Outcome
`userID`	Registration complete
Default role	App's `isDefault` role auto-assigned (when eligible)
Device record	Device registered when `X-Platform: Mobile`

If this step is removed / skipped

Next step	Result
`login-mpin`	■ 401 — `MPIN_NOT_SET`

If verify-otp was skipped

■ 400 — "account status is not verified or active"

If MPIN window expired (>30 min after verify-otp)

■ 400 — "session expired" → restart from `generate-otp`

Step 4 — Login with MPIN

Category: CAT-A · Handler: `LoginMpin` · `internal/authentication/orchestrator.go`

Endpoint

`POST /api/auth/login-mpin`

Request

```
POST /api/auth/login-mpin
Application-Name: MyApp
X-Tenant-ID: ORG_abc123
```

```
X-Platform: Mobile
Content-Type: application/json

{
  "mobileNumber": "9876543210",
  "mpin": "1234",
  "deviceId": "device-uuid-123",
  "deviceModel": "Pixel 8",
  "osVersion": "14",
  "appVersion": "1.0.0",
  "pushToken": "expo-push-token",
  "platform": "android"
}
```

Success response — 200 OK

```
{
  "code": "LOGIN_SUCCESS",
  "message": "Login successful",
  "userID": "USR12345",
  "appName": "MyApp",
  "tenantID": "ORG_abc123",
  "mobileNumber": "9876543210",
  "userName": "Jane Doe",
  "businessName": "Acme Corp",
  "role": "User",
  "permissions": ["Customer:READ", "Customer:WRITE"],
  "accessToken": "eyJhbGciOiJIUzI1NiIs...",
  "refreshToken": "eyJhbGciOiJIUzI1NiIs...",
  "accessTokenExpiresInSeconds": 1200,
  "refreshTokenExpiresInSeconds": 604800,
  "ssoSessionToken": "optional_sso_token",
  "planID": "PLAN_001"
}
```

Also set (browser clients): HttpOnly cookies `access_token`, `refresh_token`

Field	Provided	Notes
`accessToken`	■ ■	Use on all protected APIs
`refreshToken`	■ ■	Use to rotate tokens
`accessTokenExpiresInSeconds`	■	Default **1200** (20 min)
`refreshTokenExpiresInSeconds`	■	Default **604800** (7 days)
`permissions`	■	`"Module:ACTION"` strings for UI gating
`role`	■	Primary role name
`ssoSessionToken`	■	When SSO overlay enabled
`planID`	■	When tenant subscription exists

Error responses

HTTP	When
400	`deviceId` required on mobile, role not found
401	Wrong MPIN, user not registered, not org member, tenant not approved, MPIN not set
409	New device detected — must complete OTP on this device first
429	MPIN attempts exceeded — locked **10 minutes**

What this step provides

This is the **only step that issues JWT tokens** in the mobile flow.

You receive	You use it for
`accessToken`	`Authorization: Bearer <accessToken>` on API calls
`refreshToken`	`POST /api/auth/refresh-token` before access token expires
`permissions`	Client-side feature toggles
Cookies	Browser sessions (optional; body tokens work for mobile/API clients)

If this step is removed / skipped

■ No JWT tokens — user cannot call protected APIs.

Returning user (registration already done)

Skip steps 1–3. Call only: `POST /api/auth/login-mpin`

Mobile flow — Post-login operations

Category: CAT-A · Handlers: `RefreshToken`, `Logout` · `internal/authentication/orchestrator.go`

Refresh tokens

```
POST /api/auth/refresh-token
Application-Name: MyApp
X-Tenant-ID: ORG_abc123
Content-Type: application/json

{
  "refreshToken": "<refresh_token>"
}
```

Response 200:

```
{
  "accessToken": "<new_jwt>",
  "refreshToken": "<new_jwt>",
  "accessTokenExpiresInSeconds": 1200,
  "refreshTokenExpiresInSeconds": 604800,
  "permissions": ["Customer:READ"],
  "code": "TOKEN_REFRESHED",
  "message": "Tokens refreshed"
}
```

Cookie `refresh_token` takes precedence over body value.

If skipped: Access token expires after **20 minutes** → all API calls return 401.

Logout

```
POST /api/auth/logout
Application-Name: MyApp
Authorization: Bearer <access_token>
```

Response 200:

```
{
  "code": "LOGOUT_SUCCESS",
  "message": "Logged out successfully"
}
```

If skipped: Tokens remain valid until expiry or server-side revocation.

Mobile flow — Skip matrix

Skipped step	Immediate impact	Recovery
1. generate-otp	No OTP sent; no `userID`	Start from step 1
2. verify-otp	Cannot set MPIN; account unverified	Call `generate-otp` → `verify-otp`
3. set-mpin	Cannot login; `MPIN_NOT_SET`	Complete verify-otp within 30 min → `set-mpin`
4. login-mpin	No JWT tokens	Call `login-mpin` with mobile + MPIN
refresh-token (ongoing)	401 after 20 min	Call refresh before expiry
logout (optional)	Session stays active until TTL	Call logout to invalidate

Method 2 — Email + Password

Category: CAT-C (`internal/auth_email` / `auth_email.yaml`)

Flow overview

Mandatory order (new user): `register` → `verify-email` → `login`

Tokens are issued **only** at step 3 (`login`).

```
App  →  1. POST /api/auth/register       →  userID, expiresIn (no tokens)
App  →  2. POST /api/auth/verify-email   →  verified=true (no tokens)
App  →  3. POST /api/auth/login          →  accessToken + refreshToken ■
```

Step 1 — Register

Category: CAT-C · Handler: `RegisterEmailPassword` · `internal/auth_email/orchestrator.go`

Endpoint

```
POST /api/auth/register
```

Request

```
POST /api/auth/register
Application-Name: MyApp
org_id: ORG_abc123                (optional; links user to org, skips default role)
Content-Type: application/json


{
  "email": "jane@example.com",
  "password": "SecurePass1!",
  "name": "Jane Doe"
}
```

Field	Required	Rules
`email`	Yes	Valid email
`password`	Yes	8–16 chars; upper + lower + digit + special; no spaces
`name`	No	Display name

Success response — 200 OK

```
{
  "code": "OTP_SENT",
  "message": "Verification OTP sent to email",
  "userID": "USR12345",
  "expiresIn": 120
}
```

Field	Provided	Notes
`userID`	■	IAM user identifier
`expiresIn`	■	Email OTP validity — **120 seconds**
`accessToken`	—	**Not issued**
`refreshToken`	—	**Not issued**

Error responses

HTTP	When
400	Invalid email/password, unknown app
409	Email already registered and verified
429	Rate limited

What this step establishes

Delivered to client	Outcome
`userID`	Track user through flow
Email OTP	User checks email and enters OTP in step 2
Default role	Assigned when `org_id` is **not** provided

If this step is removed / skipped

Next step	Result
`verify-email`	■ 401 — invalid or expired OTP
`login`	■ 401 — "user not found"

Step 2 — Verify Email

Category: CAT-C · Handler: `VerifyEmail` · `internal/auth_email/orchestrator.go`

Endpoint

```
POST /api/auth/verify-email
```

Request

```
POST /api/auth/verify-email
Application-Name: MyApp
Content-Type: application/json

{
  "email": "jane@example.com",
  "otp": "482910"
}
```

Success response — 200 OK

```
{
  "code": "OTP_VERIFIED",
  "message": "email verified",
  "email": "jane@example.com",
  "verified": true,
  "timestamp": "2026-06-24T10:02:00Z"
}
```

Field	Provided	Notes
`verified`	■	`true` — login now allowed
`accessToken`	—	**Not issued**
`refreshToken`	—	**Not issued**

Error responses

HTTP	When
400	Missing email/OTP, invalid app
401	Wrong OTP, expired OTP, user not found

What this step establishes

Delivered to client	Outcome
`verified: true`	Account active — `login` permitted
AccountStatus	Set to active server-side

If this step is removed / skipped

Next step	Result
`login`	■ 401 — "email not verified"

If register was skipped

■ 401 — "invalid or expired OTP" / user not found

Step 3 — Login

Category: CAT-C · Handler: `LoginEmailPassword` · `internal/auth_email/orchestrator.go`

Endpoint

```
POST /api/auth/login
```

Request

```
POST /api/auth/login
Application-Name: MyApp
X-Tenant-ID: ORG_abc123          (optional; auto-resolved from user profile)
Content-Type: application/json


{
  "email": "jane@example.com",
  "password": "SecurePass1!"
}
```

Success response — 200 OK

```
{
  "code": "LOGIN_SUCCESS",
  "message": "login successful",
  "userID": "USR12345",
  "email": "jane@example.com",
  "userName": "Jane Doe",
  "appName": "MyApp",
  "tenantID": "ORG_abc123",
  "tenantName": "Acme Temple",
  "role": "User",
  "permissions": ["Customer:READ", "Customer:WRITE"],
  "accessToken": "eyJhbGciOiJIUzI1NiIs...",
  "refreshToken": "eyJhbGciOiJIUzI1NiIs...",
  "accessTokenExpiresInSeconds": 1200,
  "refreshTokenExpiresInSeconds": 604800
}
```

Field	Provided	Notes
`accessToken`	■ ■	Use on all protected APIs
`refreshToken`	■ ■	Use to rotate tokens
`accessTokenExpiresInSeconds`	■	**1200** (20 min)
`refreshTokenExpiresInSeconds`	■	**604800** (7 days)
`permissions`	■	Module permissions for UI
`tenantID` / `tenantName`	■	When org-linked

Error responses

HTTP	When
400	Missing email/password, invalid app
401	User not found, wrong password, email not verified, account blocked, **org not ACTIVE**

Org login rule: If the user is linked to an organisation, that organisation must exist with status `ACTIVE`. `PENDING` or `INACTIVE` orgs block login.

What this step provides

This is the **only step that issues JWT tokens** in the email flow.

If this step is removed / skipped

■ No JWT tokens — user cannot call protected APIs.

Returning user (already verified)

Skip steps 1–2. Call only: `POST /api/auth/login`

Email flow — Post-login operations

Category: CAT-C · Handlers: `RefreshEmailToken`, `LogoutEmail`, `GetEmailSession` · `internal/auth_email/orchestrator.go`

Refresh tokens

```
POST /api/auth/email/refresh-token
Application-Name: MyApp
Content-Type: application/json

{
  "refreshToken": "<refresh_token>"
}
```

Response 200: Same shape as LoginResponse with new tokens.

If skipped: 401 after access token expires (20 min).

Logout

```
POST /api/auth/email/logout
Application-Name: MyApp
Authorization: Bearer <access_token>
```

Response 200:

```
{
  "code": "LOGOUT_SUCCESS",
  "message": "Logout successful"
}
```

Session introspection

```
GET /api/auth/email/me
Authorization: Bearer <access_token>
```

Response 200:

```
{
  "userId": "USR12345",
  "email": "jane@example.com",
  "verified": true
}
```

Password reset (existing users)

```
POST /api/auth/forgot-password   → OTP to email
POST /api/auth/reset-password    → { email, otp, newPassword }
```

Does not issue tokens. User must `login` after reset.

Email flow — Skip matrix

Skipped step	Immediate impact	Recovery
1. register	No account; no email OTP	Start from `register`
2. verify-email	Login blocked	`register` again or resend OTP → `verify-email`
3. login	No JWT tokens	Call `login` with email + password
refresh-token (ongoing)	401 after 20 min	Call refresh before expiry
logout (optional)	Session active until TTL	Call logout to invalidate

Side-by-side comparison

Aspect	Mobile OTP + MPIN	Email + Password
Steps to first token	4	3
Token endpoint	`POST /api/auth/login-mpin`	`POST /api/auth/login`
Refresh endpoint	`POST /api/auth/refresh-token`	`POST /api/auth/email/refresh-token`
Logout endpoint	`POST /api/auth/logout`	`POST /api/auth/email/logout`
OTP channel	SMS / WhatsApp	Email
OTP expiry	120 seconds	120 seconds
Credential after registration	MPIN	Password
Setup deadline	30 min after verify-otp to set MPIN	None (verify anytime before login)
Device binding	Yes when `X-Platform: Mobile`	No
HttpOnly cookies	Yes on login-mpin	No (body tokens only)
Org login gate	Tenant approval + org membership	Org must be `ACTIVE`

JWT token reference (both methods)

Issued only at login steps. Use identically across both methods.

Claim	Value
`sub` / `userId`	`USR12345`
`appName`	Your `Application-Name`
`roles`	`["User", "Admin"]`
`org_tenant_id`	Tenant ID when org-scoped
`exp`	Access: +20 min; Refresh: +7 days
`jti`	Unique token ID

Usage:

```
Authorization: Bearer <accessToken>
Application-Name: MyApp
```

Method 3 — Google OIDC

Category: CAT-B (`internal/authentication/google_oidc_handlers.go` / `authentication.yml`)

Flow overview

Browser redirect flow: `authorize` -> Google -> `callback` -> frontend redirect with cookies

SPA/mobile flow: Google SDK -> `POST /auth/google/login` with `idToken` -> IAM JWTs

Tokens issued at: `POST /auth/google/login` or via `GET /auth/google/callback` (cookies).

GET /auth/google/authorize

```
GET /auth/google/authorize
Application-Name: MyApp
X-Tenant-ID: ORG_abc123          (optional)
```

Response 200:

```
{
  "authorizationUrl": "https://accounts.google.com/o/oauth2/v2/auth?...",
  "state": "<csrf_state>"
}
```

GET /auth/google/callback

Called by Google redirect. Sets HttpOnly cookies and redirects to per-app frontend URL.

POST /auth/google/login

```
{ "idToken": "<google_id_token_from_client_sdk>" }
```

Response 200: Same shape as `login-mpin` (`accessToken`, `refreshToken`, `userID`, etc.)

Provisioning rules:

• Without `X-Tenant-ID`: first-time users may be auto-provisioned with default app role.
• With `X-Tenant-ID`: user must already exist (invited or registered) for that tenant.

CAT-A — Mobile recovery, session, and user admin

Category: CAT-A (`internal/authentication`)

MPIN recovery flow

```
forgot-mpin -> verify-otp (or reset flow) -> reset-mpin -> login-mpin
```

POST /api/auth/forgot-mpin

```
{ "mobileNumber": "9876543210" }
```

Response 200: `{ "code", "message", "expiresIn" }` — OTP sent. **No tokens.**

If skipped: User cannot reset MPIN without this OTP.

POST /api/auth/reset-mpin

```
{
  "mobileNumber": "9876543210",
  "otp": "482910",
  "newMpin": "5678"
}
```

Response 200: MPIN updated. **No tokens** — user must `login-mpin`.

GET /api/auth/me

```
GET /api/auth/me
Application-Name: MyApp
Authorization: Bearer <access_token>
```

Response 200: Current user/session for mobile auth. **No new tokens.**

GET /api/auth/delete-account

```
GET /api/auth/delete-account
Application-Name: MyApp
Authorization: Bearer <access_token>
```

Response 200: Soft-deletes authenticated user. **No tokens.**

POST /api/auth/addRoleToUser

```
{ "mobileNumber": "9876543210", "roleName": "Admin" }
```

Adds IAM role to mobile user. **No tokens.**

POST /api/auth/initiate-mobile-change

```
{ "mobileNumber": "9876543210", "userName": "Jane" }
```

Sends OTP to new mobile. Requires auth. **No tokens.**

POST /api/auth/verify-mobile-change

```
{ "mobileNumber": "9876543210", "otp": "482910" }
```

Applies mobile change. Requires auth. **No tokens.**

POST /api/auth/freelancer-role-auto-tag

```
{ "userId": "USR12345", "roleIds": ["<role_object_id>"] }
```

Tags freelancer roles after MPIN setup. **No tokens.**

GET /api/auth/users | GET /api/auth/users/{userId} | PUT /api/auth/users/{userId}/status

Admin user listing, detail, and status update. Require `Application-Name` (+ auth). **No tokens.**

CAT-C — Email recovery and profile

Category: CAT-C (`internal/auth_email/orchestrator.go`)

Password recovery flow

```
forgot-password -> reset-password -> login
```

POST /api/auth/forgot-password

```
{ "email": "jane@example.com" }
```

Response 200: OTP sent to email (`expiresIn: 120`). **No tokens.**

POST /api/auth/reset-password

```
{
  "email": "jane@example.com",
  "otp": "482910",
  "newPassword": "NewSecure1!"
}
```

Response 200: Password updated. **No tokens** — user must `login`.

POST /api/auth/add-role-to-user

```
{ "email": "jane@example.com", "roleName": "ORG_MEMBER" }
```

Assigns org role by email. Header `org_id` optional. **No tokens.**

PUT /api/auth/user/{userId}/update

```
{ "newName": "Jane Smith" }
```

Updates user profile. **No tokens.**

CAT-D — Organisation invite flow

Category: CAT-D (`internal/auth_email/invites.go` / `auth_email.yaml`)

Flow overview

```
invite (admin) -> accept-invite (public) -> tokens issued
```

Alternative onboarding to `register` + `verify-email` + `login`.

POST /api/auth/invite (admin)

```
{
  "email": "newuser@example.com",
  "roleName": "ORG_MEMBER",
  "name": "New User"
}
```

Headers: `Authorization`, `Application-Name`, optional `org_id`.

Response 200: `{ "inviteId", "email", "expiresAt" }`. **No tokens.**

GET /api/auth/invites (admin)

List invites for org. Query `status` optional.

GET /api/auth/invite/{token} (public)

Preview invite for accept UI. **No auth required.**

POST /api/auth/invite/{inviteId}/revoke (admin)

Revokes pending invite.

POST /api/auth/accept-invite (public)

```
{
  "token": "<invite_token_from_email>",
  "password": "SecurePass1!",
  "name": "New User"
}
```

Response 200: `LoginResponse` with `accessToken` + `refreshToken`. **Issues tokens.**

CAT-E — Organisation onboarding

Category: CAT-E (`internal/rbac/orchestrator.go` / `rbac.yml`)

Used before or alongside email/mobile auth for multi-tenant apps.

POST /api/auth/create_organizations

```
POST /api/auth/create_organizations
Application-Name: MyApp
User_Id: USR12345
Authorization: Bearer <token>


{ "name": "Acme Temple" }
```

Response 201: `{ "tenant_id", "name", "status": "PENDING" }`. **No tokens.**

POST /api/auth/assign_organizations

```
{
  "user_id": "USR12345",
  "org_id": "ORG_abc123"
}
```

Response 200: Org linked to user; status may move PENDING -> ACTIVE. **No tokens.**

Typical sequence: User registers (CAT-A or CAT-C) -> `create_organizations` -> `assign_organizations` -> invite teammates (CAT-D).

Complete API catalog (all 38 endpoints)

Cat	Method	Endpoint	Handler (code)	Issues tokens	Doc section
CAT-A	POST	`/api/auth/generate-otp`	`GenerateOtp`	No	Method 1 Step 1
CAT-A	POST	`/api/auth/verify-otp`	`VerifyOtp`	No	Method 1 Step 2
CAT-A	POST	`/api/auth/set-mpin`	`SetMpin`	No	Method 1 Step 3
CAT-A	POST	`/api/auth/login-mpin`	`LoginMpin`	**Yes**	Method 1 Step 4
CAT-A	POST	`/api/auth/refresh-token`	`RefreshToken`	Rotates	Method 1 post-login
CAT-A	POST	`/api/auth/logout`	`Logout`	Revokes	Method 1 post-login
CAT-A	POST	`/api/auth/forgot-mpin`	`ForgotMpin`	No	CAT-A recovery
CAT-A	POST	`/api/auth/reset-mpin`	`ResetMpin`	No	CAT-A recovery
CAT-A	GET	`/api/auth/me`	`GetCurrentSession`	No	CAT-A session
CAT-A	GET	`/api/auth/delete-account`	`DeleteAccount`	No	CAT-A session
CAT-A	POST	`/api/auth/addRoleToUser`	`AddRoleToUser`	No	CAT-A admin
CAT-A	POST	`/api/auth/initiate-mobile-change`	`InitiateMobileChange`	No	CAT-A profile
CAT-A	POST	`/api/auth/verify-mobile-change`	`VerifyMobileChange`	No	CAT-A profile
CAT-A	POST	`/api/auth/freelancer-role-auto-tag`	`FreelancerRoleAutoTag`	No	CAT-A onboarding
CAT-A	GET	`/api/auth/users`	`ListUsers`	No	CAT-A admin
CAT-A	GET	`/api/auth/users/{userId}`	`GetUserById`	No	CAT-A admin
CAT-A	PUT	`/api/auth/users/{userId}/status`	`UpdateUserStatus`	No	CAT-A admin
CAT-B	GET	`/auth/google/authorize`	`GoogleOidcAuthorize`	No	Method 3
CAT-B	GET	`/auth/google/callback`	`GoogleOidcCallback`	Cookies	Method 3
CAT-B	POST	`/auth/google/login`	`GoogleOidcLogin`	**Yes**	Method 3
CAT-C	POST	`/api/auth/register`	`RegisterEmailPassword`	No	Method 2 Step 1
CAT-C	POST	`/api/auth/verify-email`	`VerifyEmail`	No	Method 2 Step 2
CAT-C	POST	`/api/auth/login`	`LoginEmailPassword`	**Yes**	Method 2 Step 3
CAT-C	POST	`/api/auth/email/refresh-token`	`RefreshEmailToken`	Rotates	Method 2 post-login
CAT-C	POST	`/api/auth/email/logout`	`LogoutEmail`	Revokes	Method 2 post-login

Cat	Method	Endpoint	Handler (code)	Issues tokens	Doc section
CAT-C	GET	`/api/auth/email/me`	`GetEmailSession`	No	Method 2 post-login
CAT-C	POST	`/api/auth/forgot-password`	`ForgotEmailPassword`	No	CAT-C recovery
CAT-C	POST	`/api/auth/reset-password`	`ResetEmailPassword`	No	CAT-C recovery
CAT-C	POST	`/api/auth/add-role-to-user`	`AddEmailRoleToUser`	No	CAT-C admin
CAT-C	PUT	`/api/auth/user/{userId}/update`	`UpdateUser`	No	CAT-C profile
CAT-D	POST	`/api/auth/invite`	`InviteUser`	No	CAT-D invites
CAT-D	GET	`/api/auth/invites`	`ListInvites`	No	CAT-D invites
CAT-D	GET	`/api/auth/invite/{token}`	`GetInviteByToken`	No	CAT-D invites
CAT-D	POST	`/api/auth/invite/{inviteId}/revoke`	`RevokeInvite`	No	CAT-D invites
CAT-D	POST	`/api/auth/accept-invite`	`AcceptInvite`	**Yes**	CAT-D invites
CAT-E	POST	`/api/auth/create_organizations`	`MTCreateOrganization`	No	CAT-E org
CAT-E	POST	`/api/auth/assign_organizations`	`MTAssignOrganizationToUser`	No	CAT-E org

This document reflects `authentication.yml`, `auth_email.yaml`, and org auth paths in `rbac.yml`. Coordinate with your platform team for environment URLs, registered application names, and JWT signing configuration.